02_INSTRUCTOR_ANSWER_KEY

Pintop | 2026 Training

Authorisation, RBAC & API Security - instructor expected outcomes and response prompts

Reference source: `codebase/app/Http/Middleware/BearerToken.php`

Original lesson steps

1. **Show an endpoint with no permission check. Then say: “Being logged in is not the same as being allowed. Demonstrate the customer editing someone else's order.”**
2. **Add roles and permissions. Then say: “Customer, support, admin. Each role carries a set of permissions.”**
3. **Enforce the check on the resource. Then say: “Ask: does this user's role allow this action on this resource? One clear check in one place.”**
4. **Review the boundary. Then say: “Tighten CORS, use HTTPS, and make sure tokens cannot leak.”**

Oral questions and example answers

- **Ask:** "What is the difference between authentication and authorisation?" **Expected answer:** authentication is who you are; authorisation is what you are allowed to do.
- **Ask:** "What is least privilege here?" **Expected answer:** giving each role only the permissions its job needs.
- **Ask:** "Why is a missing permission check so dangerous?" **Expected answer:** a logged-in user can act on data that is not theirs.

Assessing student evidence

Accept work when students can open the correct source, explain one meaningful code statement, demonstrate a valid local check, describe one error case and save their work in a disposable copy. Do not mark a blocked environment as passing. Do not mark raw copied code without explanation as complete.

Teacher troubleshooting

When a student is stuck, ask: "Show me the exact line you changed. What was the expected result? Which command did you actually run? What did it return?" Check the working directory and dependencies before changing code.